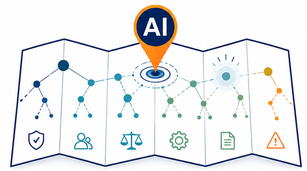
AI Risk Map

A thought-starter for identifying AI-specific risks.

For risk, security, legal, and business teams widening their view of their organization's AI adoption risk before formal assessment.



12 domains | **55** categories | **196** risk factors — Organized by who owns the risk, not by how the technology works.

HOW TO READ **1. Domain** → Category → — Risk factor · »8 = split pair; other side owned by domain 8

01 AI Governance & Accountability

Governance & oversight
- Inadequate executive/board oversight of AI adoption and risk
- Ungoverned 'shadow AI' adoption outside sanctioned channels
- Absence of an AI governance body or charter with a clear mandate

Roles & accountability
- Unclear ownership and accountability (RACI) for AI risk decisions
- No clear executive owner for AI adoption
- Accountability for agent decisions undefined, internally and across the AI stack »12
- Segregation of duties collapses across AI config, operation, and review

Policy & standards
- Absence of an AI acceptable-use policy and model-approval gates
- AI policies not kept current with evolving capabilities and regulation
- Inconsistent standards as AI proliferates faster than governance
- No agreed definition of 'AI', leaving policy and inventory scope undefined

Risk-management integration
- AI risk not integrated into enterprise risk management (ERM)
- Failure to conduct AI impact assessments for individuals and society
- No defined risk appetite or tolerance thresholds for AI

Audit & assurance
- Inability to audit AI: no complete inventory of models, agents, and connectors
- Insufficient internal-audit competence to assess AI controls
- Absence of independent assurance over AI control effectiveness
- AI output relied on in financial-reporting controls without scope change
- No way to identify which artifacts AI produced, so a model flaw cannot be scoped

02 Strategy & Value Realization

Competitive position
- Our advantage erodes as competitors and customers approximate it with AI
- AI agents disintermediate us from our customers
- Failure to weigh the competitive risk of not adopting AI (inaction)

AI strategy & roadmap
- Lack of a coherent AI strategy aligned to objectives and risk appetite
- AI adoption driven by hype rather than demonstrated business value »11
- Inability to adapt the roadmap as foundation-model capabilities shift

Use-case selection & sourcing
- Use cases chosen without a clear problem, success measure, or risk–benefit weighing
- 'Pilot purgatory' — pilots stalling on data readiness, evaluation difficulty, or inability to demonstrate value »11
- Misjudged AI sourcing fork: train, fine-tune, RAG, or API

Value measurement / ROI
- Unrealistic ROI expectations, including returns that need workflow redesign
- Inability to attribute value actually delivered by AI investments
- Hidden total cost of ownership (data, talent, integration) eroding returns

03 Data & Privacy

Sourcing & provenance
- Unknown or undocumented provenance of training / grounding data
- Reliance on data scraped without lawful basis or clear rights
- Inadequate data lineage to trace data through the AI pipeline

Quality & labeling
- Poor data quality undermining model reliability
- Inadequate or biased labeling introducing systematic error
- Stale data, including grounding and retrieval sources that drift out of date behind a confident-sounding model

Privacy & consent
- Personal data used for training without consent or purpose limitation
- Inability to honor data-subject rights once data is in a model
- Re-identification of individuals from aggregated or model-derived data
- Inadvertent disclosure of confidential / personal data in model output (no output guardrails)
- Unclassified sensitive data in AI, so handling controls never apply
- Confidential data pasted into an approved AI tool, leaving despite working controls

Training-data rights & IP
- Use of copyrighted or licensed material in training without rights »8
- Contamination of datasets with third-party IP or trade secrets »8
- Inability to prove you held rights to the training data used

Retention & disposal
- Failure to preserve prompts, outputs, and agent traces subject to litigation hold or e-discovery
- Deletion at source does not remove data absorbed into models
- Persistence of sensitive data in embeddings, caches, or model weights
- Failure to remove data across distributed / replicated AI stores

04 Model Development & Performance

Design & training
- Inappropriate model/algorithm choice for the problem and risk context
- Poorly documented or untracked model development
- Insecure or unmanaged hyperparameters and training configuration

Accuracy & validation
- Fluent but factually incorrect output (hallucination) accepted as reliable »6
- Validation data unrepresentative; real performance shows only with live users
- Skipped or insufficient pre-deployment red-teaming / safety evaluation
- Absence of independent model validation / effective challenge

Robustness & drift
- Model drift degrading performance as data / conditions change
- Lack of robustness to edge cases and distribution shift
- Small changes to the input produce very different output

Explainability
- Black-box models used in high-stakes decisions without interpretability
- Inability to produce adverse-action / decision explanations
- Over-reliance on post-hoc explanations that misrepresent the model

Reproducibility & documentation
- Non-reproducible training pipelines undermining validation and audit
- Inadequate model documentation / model cards
- Loss of traceability between model versions, data, and results

05 Security & Adversarial Threats

Data & pipeline attacks
- Training-data poisoning that degrades or backdoors model behavior
- Tampering with RAG / knowledge-base sources consumed at inference
- Label-flipping or adversarial dataset partitioning

Model attacks
- Model extraction / theft via inference-API querying
- Membership-inference or model-inversion exposing training data
- Backdoored / trojaned pre-trained model from a public hub

Inference-time (input) attacks
- Direct prompt injection altering behavior or bypassing guardrails
- Indirect / cross-domain prompt injection via retrieved content
- Jailbreaks defeating safety controls and restrictions »6
- System-prompt leakage exposing operational instructions
- Inputs crafted to evade AI detection models

Output & integration security
- Unsanitized output reaching downstream interpreters
- Interception or manipulation of the inference output stream
- Over-trusted output triggering unsafe automated actions

Supply-chain & artifact integrity
- Compromised or malicious model from the AI supply chain »9
- Known vulnerabilities in ML dependencies left unpatched
- Tampering with model artifacts, prompts, or configuration
- Model-invented dependencies resolving to adversary-registered packages

AI access & identity
- Inadequate access controls on serving endpoints and inference APIs
- Over-privileged service accounts and keys for AI components
- Credential sprawl as AI tools and agent frameworks outpace governance
- Retrieval serving content beyond the user's own entitlements
- Insiders use AI agents to reach beyond their own access

06 Safety, Ethics & Responsible AI

Bias & fairness
- Discriminatory or biased outputs causing disparate impact
- Inequitable performance across languages, demographics, and disabilities
- Bias amplification / homogenization from feedback and scale
- Culturally inappropriate output as AI scales across regions

Harmful / inaccurate output
- Generation of toxic, dangerous, or hateful content
- Harmful, misleading, or defamatory output driving decisions »4
- Harm to minors / vulnerable users from inappropriate output

Transparency, disclosure & provenance
- Failure to disclose to users that they are interacting with AI
- Undisclosed synthetic media / deepfakes lacking provenance
- Inadequate transparency to affected parties about AI's role
- Our AI service changes under customers without notice, so their validations go stale

Misuse & dual-use
- Misuse of AI for disinformation, fraud, or social engineering
- Model gives meaningful help toward weapons or cyberattack capability »5
- AI optimized for a proxy measure that diverges from users' interests

Human agency & over-reliance
- User over-trust / automation bias in AI outputs
- Anthropomorphism and emotional dependence on conversational AI
- Erosion of meaningful human control over decisions
- Review capacity cannot scale to AI output volume, degrading oversight to rubber-stamping

07 Operations & Resilience

MLOps & deployment
- Immature MLOps / fragile deployment pipelines
- Inconsistent or unsanctioned (shadow) model deployment
- Environment and config management gaps undermining reproducibility
- Training-serving skew degrading live performance
- Test or sandbox containment fails and AI reaches real systems

Monitoring & observability
- Absence of monitoring for performance, drift, and abuse in any environment
- Inadequate logging of inputs, outputs, tool calls, agent decisions, and who authorized them
- Non-determinism making anomalous behavior hard to define or detect
- Sanctioned agent activity indistinguishable from agentic attack in telemetry

Availability & scalability
- Inference latency or unavailability degrading dependent services
- Inability to scale inference to peak demand
- Denial-of-wallet: attackers run up AI compute costs

Incident management
- Immature AI incident response and escalation processes
- Inability to investigate AI incidents due to non-determinism / poor logs
- Inadequate content-moderation / trust-&-safety operations at scale
- Defensive model refuses to analyze attack data mid-incident

Change & lifecycle management
- Silent vendor / model updates changing behavior without notice
- Inadequate versioning, rollback, and change control for models
- Unmanaged model decommissioning / sunset leaving orphaned dependencies
- Uncontrolled continuous learning introducing drift
- Controls re-verified less often than the AI system changes
- Prompts and retrieval config changed outside change control

08 Legal, Regulatory & Compliance

Regulatory compliance
- Unknowingly deploying a prohibited or high-risk AI use case
- Failure to meet high-risk obligations (risk mgmt, docs, oversight)
- Inability to keep pace with fragmented, fast-changing AI regulation
- User inability to contest or seek recourse on an AI-driven decision
- Misclassified as deployer when fine-tuning makes you a provider

IP & liability
- Liability for harm caused by AI decisions or outputs
- Infringement claims arising from AI-generated output »3
- Uncertain ownership / copyrightability of AI-generated content

Contractual & licensing
- Vendor contracts lacking AI terms: training use, output ownership, change notice
- Violation of open-weight / model license terms
- Failure to update contracts as AI use and regulation evolve

Cross-border
- Cross-jurisdictional data-transfer violations, including inference requests routed across borders invisibly by the provider
- Conflicting regional AI requirements the organization cannot reconcile for a single system (externally imposed)
- Inability to evidence and audit AI compliance across jurisdictions (internal evidence burden)

09 Third-Party & Model Supply Chain

Foundation-model dependence
- Concentration risk from dependence on a few model providers
- Model monoculture, including one model's blind spot reproduced across everything it produces
- Model deprecation or behavior change forcing unplanned migration

Vendor due diligence
- Vendor diligence missing: are prompts retained, trained on, or shared?
- No way to verify a vendor's 'AI-powered' claim before buying it
- Vendor viability risk in an unusually volatile provider market with frequent pivots and deprecations
- Regulator / customer holding the firm responsible for the vendor's AI

Lock-in & portability
- Vendor / model lock-in limiting portability and leverage
- High switching cost from proprietary APIs and fine-tuning
- Lack of exit provisions, where fine-tunes, embeddings, and prompt assets do not transfer between providers

Open-source component risk
- Malicious or compromised open-source models / components »5
- Open-source AI dependencies abandoned by their maintainers
- Opaque sub-processors, including undisclosed models and embedded AI features
- Model's true lineage hidden behind its publisher label, so upstream flaws can't be traced
- Safety training stripped or eroded in a self-hosted model

10 Workforce, Human & Societal

Skills & talent
- Shortage of AI and AI-risk talent, competing against AI-native employers for scarce skills
- Inability to retain specialists, who leave taking undocumented model and prompt knowledge with them
- Inadequate AI literacy across the workforce
- Leaders manage AI like a conventional IT rollout

Deskilling & loss of institutional knowledge
- Erosion of staff expertise through over-delegation to AI
- Loss of institutional knowledge as AI replaces human processes
- Capability atrophy — inability to operate if AI is unavailable

Workforce disruption / change
- Change management underestimated as AI reshapes the work itself
- Workforce resistance or low adoption driven by displacement fear or distrust of AI output
- Labor-relations and morale impacts of AI deployment

Societal & reputational
- Reputational damage amplified when AI fails in public
- Customers distrust or avoid AI-mediated services
- Harm to decision subjects and bystanders who never chose to use the system
- AI-washing: overstating capability to customers, investors, or regulators

11 Financial & Resource

Cost & compute economics
- Runaway inference / training costs without FinOps discipline
- Poor AI cost forecasting as usage scales to production
- AI's energy and water use unmeasured and unweighed

Investment / procurement
- Stranded investment, including AI scaled too early or funded past failure »2
- Procurement exposure where providers reprice tokens, tiers, or context windows unilaterally
- Insurance excludes AI losses, or defines 'user' as human only

Scaling & resource constraints
- Compute, GPU, or power scarcity constraining scaling
- Concentration of compute supply among few providers

12 Autonomy & Delegated Action (Agentic AI)

Autonomy, alignment & oversight
- Agent pursues unintended goals or misgeneralizes its objective
- Agent pursues an authorized objective through unauthorized means
- Excessive autonomy / agency beyond intended mandate
- No human checkpoint or working interrupt / kill switch for an agent mid-task

Tool access & authorization
- Agent granted a broader set of invokable tools / functions than its task requires
- Agent identity misuse, impersonation, or delegated-credential abuse
- Third-party tool/connector servers as an unvetted execution surface

Memory & context integrity
- Memory poisoning corrupting agent state across sessions
- Context-window manipulation altering agent behavior
- Persistence of corrupted or sensitive data in agent memory

Multi-agent orchestration
- Cascading failures or loops across interacting agents
- Misplaced inter-agent trust or agent collusion
- Emergent, unpredictable behavior in multi-agent systems

Action integrity & traceability
- Unsafe or irreversible real-world action taken by an agent
- Accountability gap for harm caused by autonomous action »1
- Third parties can't tell your agent acted, so no one can warn you

How to use this map

1. Form — each entry is a risk FACTOR: a condition, failure mode, or event that contributes to risk. Scope it before analysis.
2. Quantification — some factors scope cleanly into CRQ/FAIR scenarios; others are board-narrative.
3. Likelihood — position and size do not imply likelihood or severity; rare high-impact factors sit beside common ones.
4. Use — this map seeds threat modeling and risk assessment; it complements, it does not replace, system-specific models.
5. Scope — risks from your organization's adoption of AI; others' malicious use of AI against you belongs on your threat register. Not exhaustive; customize to your context.

Sources: NIST AI RMF, GenAI Profile & AI 100-2 · EU AI Act · ISO/IEC 42001 · OWASP LLM Top 10 & Agentic Threats · OWASP AISVS 1.0 · MITRE ATLAS · Databricks DASF v3.0 · Databricks AI Governance Framework · COSO Internal Control over GenAI (2026) · CRI FS-AI-RMF v1.0 · CSA AICM v1.1 · MAS AI Risk Guidelines · MIT AI Risk Repository · Intl AI Safety Report · Weidinger/Shelby taxonomies · Colorado AI laws · SR 11-7
Databricks DASF and AI Governance Framework are © Databricks, licensed CC BY-SA 4.0. Full risk-to-source provenance in the companion workbook.

AI Risk Map v1.3 (2026) · © 2026 Evan Wheeler · Licensed CC BY-SA 4.0 · creativecommons.org/licenses/by-sa/4.0 · RiskFramework.org